VERTEX CAPITAL GROUP - BT YÖNETİŞİMİ VE İÇ KONTROL DENETİM RAPORU

Denetlenen Kurum: Vertex Capital Group

Denetim Alanı: BT Yönetişimi ve İç Kontrol (COBIT 2019)

İncelenen Dönem: 2021 - Q1 2026 dokümanları

Denetçi: Necdet Emre Bayraktar (Bilgi Sistemleri Denetçisi)

1. Yönetici Özeti

Bu rapor, 18 ülkede faaliyet gösteren, 11.500 çalışanı bulunan ve 78 milyar EUR varlık yöneten, ISO 27001 sertifikalı Vertex Capital Group'un BT yönetişimi ve iç kontrol yapısına ilişkin denetim bulgularını içermektedir. Şirket yönetimi; BT yönetişiminin etkin işletildiği, Yönetim Kurulunun BT risklerini düzenli takip ettiği, risk iştahının tanımlandığı, iç kontrollerin etkin çalıştığı, KPI/KRI yapılarının olgun olduğu ve yönetim raporlamalarının güvenilir olduğu yönünde denetim ekibine güvence vermiş, COBIT çerçevesini kullandığını beyan etmiştir.

Ancak gerçekleştirilen kanıta dayalı bağımsız denetim sonucunda, yönetimin verdiği sekiz güvencenin hiçbirinin kanıtlarla desteklenmediği tespit edilmiştir. Yönetim Kuruluna sunulan Siber Dashboard'da **0 kritik zafiyet, 0 açık denetim bulgusu ve %96 yama uyumluluğu** raporlanırken; KRI Dashboard ve Bilgi Güvenliği Komitesi kayıtlarında **127 kritik ve 612 yüksek zafiyet, 24 açık denetim bulgusu ve %64 yama uyumluluğu** bulunmaktadır. KPI ve KRI tablolarındaki hedeflerin tamamı tutturulamamış olmasına rağmen tüm göstergeler "Green" olarak işaretlenmiş, iç kontrol matrisindeki tüm kontroller kanıt eklenmeden "Pass" olarak raporlanmış ve COBIT öz değerlendirmesinde tüm süreçlere kanıtsız olarak en yüksek puan (5) verilmiştir.

Mevcut durum; BT yönetişiminin kağıt üzerinde kaldığını, Yönetim Kurulunun şirketin gerçek risk profilini göremediğini ve yönetim raporlamalarının güvenilir olmadığını göstermektedir. Bu tablo, 78 milyar EUR varlık yöneten bir yatırım şirketi için ciddi regülasyon (DORA, NIS2), itibar ve siber güvenlik riski oluşturmaktadır.

2. Denetim Kapsamı

Bu denetim, yönetimin verdiği güvencelerin doğrulanması amacıyla Vertex Capital Group'un BT yönetişim yapısını COBIT 2019 çerçevesi esas alınarak aşağıdaki alanlarda kapsamaktadır:

- Yönetişim ve Yönetim Kurulu Gözetimi (EDM01, EDM03)
- BT Stratejisi, Portföy ve Bütçe Yönetimi (APO02, APO05, APO06, BAI01)
- Organizasyon Yapısı, Roller ve Sorumluluklar (APO01, APO07)
- BT Risk Yönetimi ve Risk İştahı (APO12, EDM03)
- Tedarikçi ve Politika Yönetişimi (APO10, APO01)

- Performans İzleme, İç Kontrol ve Güvence (MEA01, MEA02, MEA03)

3. Yapılan Testler

Yönetim beyanlarına güvenilmeden, kurum tarafından sağlanan 20 doküman incelenmiş ve birbirleriyle çapraz olarak karşılaştırılmıştır:

- IT Governance Charter, Policy Governance Standard ve Vendor Governance Framework dokümanlarının güncellik ve içerik açısından incelenmesi.
- Board Technology Committee, IT Steering Committee (14 Mart 2026) ve Information Security Committee (Şubat 2026) toplantı kayıtlarının karar, aksiyon ve katılım açısından incelenmesi.
- IT Strategy 2024-2026 ile Project Portfolio Report (Q1 2026) ve IT Budget Report'un karşılaştırılması.
- Board Cyber Dashboard'un KPI Dashboard (Q1 2026), KRI Dashboard, Audit Issue Tracker ve komite kayıtlarıyla karşılaştırılması.
- Enterprise Risk Appetite Statement ve IT Risk Register'ın gerçekleşen risk göstergeleriyle karşılaştırılması.
- Internal Control Matrix, RACI Matrix, IT Organization Chart, Internal Audit Plan 2026 ve COBIT Self Assessment'ın kanıt ve bağımsızlık açısından değerlendirilmesi.

4. Yönetim Beyanları ve Denetim Sonuçları

Yönetim Beyanı	Sonuç	Kanıt
BT yönetişimi etkin şekilde işletilmektedir.	Karşılanmıyor	Charter 2021'den beri gözden geçirilmemiş; eskalasyon, risk sahipliği ve karar yetkisi tanımsız (Bulgu 5.1.1).
Yönetim Kurulu BT risklerini düzenli takip etmektedir.	Karşılanmıyor	Kurul toplantı kaydı yok; Kurul Dashboard'u gerçek verileri yansıtmıyor (Bulgu 5.1.2, 5.1.4).
Kritik kararlar uygun komitelerde alınmaktadır.	Karşılanmıyor	Steering Committee'de karar ve aksiyon yok; InfoSec Committee'de sorumlu ve tarih yok (Bulgu 5.3.1, 5.3.2).
BT stratejisi iş hedefleri ile uyumludur.	Karşılanmıyor	Stratejide "Green" görünen programlar portföyde Red/Amber; 8-11 ay gecikme (Bulgu 5.2.1).
Risk iştahı tanımlanmıştır.	Kısmen	"Low" iştah tanımlı ancak metrik, eşik, eskalasyon ve Kurul onayı yok (Bulgu 5.1.3).
İç kontroller etkin şekilde çalışmaktadır.	Karşılanmıyor	Tüm kontroller kanıtsız "Pass"; aynı alanlarda 5 açık iç denetim bulgusu (Bulgu 5.5.3).

Yönetim Beyanı	Sonuç	Kanıt
KPI ve KRI yapıları olgundur.	Karşılanmıyor	Hedefi tutmayan tüm göstergeler "Green" (Bulgu 5.5.1, 5.5.2).
Yönetim raporlamaları güvenilirdir.	Karşılanmıyor	Aynı metrik için üç farklı değer (açık bulgu: 0 / 5 / 24) (Bulgu 5.1.4, 5.5.4).

5. Tespit Edilen Bulgular

5.1 Yönetişim ve Yönetim Kurulu Gözetimi (COBIT EDM01 / EDM03)

Bulgu 5.1.1 - BT Yönetişim Şartı (IT Governance Charter): Charter Versiyon 1.0 olup Ocak 2021'den beri yürürlüktedir ve gözden geçirme tarihi tanımlanmamıştır (Not Defined). Eskalasyon süreci, risk sahipliği, karar yetki matrisi ve kontrol etkinliği gözden geçirmesi tanımlanmamıştır. Charter'a göre Teknoloji Komitesi yalnızca "tavsiye veren" bir yapı olmasına rağmen IT Strategy 2024-2026 dokümanı "Approved By: Technology Committee" olarak onaylanmıştır.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Yönetişim çerçevesinin tek seferlik bir doküman olarak hazırlanması ve karar/onay yetkilerinin hiçbir zaman netleştirilmemesi.
- **Öneri:** Charter güncellenmeli; karar yetki matrisi, eskalasyon kriterleri, risk sahipliği ve yıllık gözden geçirme döngüsü tanımlanarak Yönetim Kurulu onayına sunulmalıdır.

Bulgu 5.1.2 - Yönetim Kurulu Teknoloji Komitesi Kayıtları: "Board Technology Committee Minutes" olarak sunulan doküman bir toplantı tutanağı değildir; içeriği 2022 tarihli risk iştahı metninden ibarettir. Toplantı tarihi, katılımcı, gündem, karar ve aksiyon bilgisi bulunmamaktadır. Charter'da tanımlanan üç aylık (Quarterly) toplantıların yapıldığına dair kanıt sunulamamıştır.

- **Risk Seviyesi: Critical**
- **Root Cause Analysis (RCA):** Yönetim Kurulu seviyesinde BT gözetiminin fiilen işletilmemesi ve komite sekretarya/kayıt süreçlerinin olmaması.
- **Öneri:** Teknoloji Komitesi charter'daki sıklıkla toplanmalı; her toplantıda gündem, katılım, kararlar, aksiyon sahipleri ve tarihler resmi tutanakla kayıt altına alınmalıdır.

Bulgu 5.1.3 - Risk İştahı (Risk Appetite): Enterprise Risk Appetite Statement (Versiyon 1.0, Mart 2022) Siber ve Teknoloji riskleri için "Low" iştah tanımlamaktadır. Ancak risk metrikleri, eşik değerleri (Escalation Threshold) ve eskalasyon kriterleri tanımlanmamış, Yönetim Kurulu onayı kanıtlanamamıştır (Not Evidenced). "Düşük" risk iştahına rağmen 127 kritik ve 612 yüksek zafiyet bulunmakta, bu durum hiçbir eskalasyonu tetiklememektedir.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Risk iştahının ölçülebilir göstergelere bağlanmaması; KRI eşiklerinin risk iştahından türetilmemesi.

- **Öneri:** Risk iştahı ölçülebilir metrik ve eşiklerle (ör. kritik zafiyet <10) yeniden tanımlanmalı, KRI Dashboard ile ilişkilendirilmeli ve Yönetim Kurulu tarafından onaylanmalıdır.

Bulgu 5.1.4 - Yanıltıcı Yönetim Kurulu Siber Raporlaması: Board Cyber Dashboard'da Siber Risk ve Genel Durum "GREEN", kritik zafiyet 0, açık denetim bulgusu 0, yama uyumluluğu %96, üçüncü taraf riski 0 olarak raporlanmıştır. Oysa KRI Dashboard'da 127 kritik zafiyet, 24 açık denetim bulgusu ve 32 tedarikçi riski; KPI Dashboard ve Bilgi Güvenliği Komitesi kayıtlarında %64 yama uyumluluğu; Audit Issue Tracker'da 5 açık iç denetim bulgusu bulunmaktadır.

- **Risk Seviyesi: Critical**
- **Root Cause Analysis (RCA):** Kurul raporlarının operasyonel kaynaklardan bağımsız, manuel ve doğrulanmadan hazırlanması; olumsuz bilginin yukarıya taşınmasını engelleyen yönetim kültürü.
- **Öneri:** Kurul raporları KRI/KPI ve tarama araçlarından otomatik üretilmeli, Risk Yönetimi veya İç Denetim tarafından bağımsız olarak doğrulanmalıdır. Mevcut raporlama farkı Yönetim Kuruluna derhal açıklanmalıdır.

5.2 BT Stratejisi, Portföy ve Bütçe Yönetimi (COBIT APO02 / APO05 / APO06 / BAI01)

Bulgu 5.2.1 - Strateji ile Portföy Arasındaki Uyumsuzluk: IT Strategy 2024-2026'da tüm stratejik programlar "Green" olarak gösterilmektedir. Q1 2026 Project Portfolio Report'a göre ise IAM Programı "Red" (11 ay gecikme, %28 bütçe aşımı), Cloud Migration "Amber" (8 ay gecikme, %34 bütçe aşımı), SIEM Modernization "Amber" ve DR Automation "Red" durumdadır ve kaynak eksikliği "Critical" seviyededir. Ayrıca SIEM bütçesi stratejide €1,1M, portföyde €1,8M olarak görünmekte; Zero Trust Programı portföyde yer almazken DR Automation stratejide bulunmamaktadır. Stratejik KPI hedefleri de tutturulamamıştır (yama uyumluluğu hedef >%95, gerçekleşen %64; erişilebilirlik hedef %99,95, gerçekleşen %99,1).

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Strateji dokümanının hazırlandıktan sonra izlenmemesi; portföy yönetimi ile strateji arasında düzenli bir gözden geçirme ve raporlama bağlantısının olmaması.
- **Öneri:** Strateji ve portföy tek bir program yönetim çerçevesinde birleştirilmeli, program durumları ve bütçeler çeyreklik olarak Yönetim Kuruluna gerçek değerlerle raporlanmalıdır.

Bulgu 5.2.2 - Kullanılmayan Güvenlik Bütçesi: €38M yıllık BT bütçesinin €2,1M'si güvenliğe ayrılmış, bunun yalnızca €0,8M'si harcanmış ve €1,3M (%62) kullanılmamıştır. Aynı dönemde IAM Transformation ek finansman beklemekte (IT Steering Committee, 14 Mart 2026), kaynak eksikliği "Critical" olarak raporlanmakta ve 127 kritik zafiyet açık durmaktadır.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Bütçe kullanımının risk önceliklerine göre yönetilmemesi ve bütçe kararlarının alınacağı etkin bir komite mekanizmasının bulunmaması.

- **Öneri:** Kullanılmayan güvenlik bütçesi öncelikle kritik zafiyet giderimi ve IAM programına yönlendirilmeli; bütçe kullanımı aylık olarak takip edilmelidir.

5.3 Organizasyon ve Komite İşleyişi (COBIT APO01 / APO07)

Bulgu 5.3.1 - IT Steering Committee'de Karar ve Aksiyon Olmaması: 14 Mart 2026 tarihli toplantıya yalnızca CIO, Infrastructure Manager ve PMO katılmış; CISO, Risk Officer ve İç Denetim katılmamıştır. Cloud Migration gecikmesi ve IAM ek finansman ihtiyacı görüşülmesine rağmen hiçbir karar, aksiyon maddesi veya risk eskalasyonu kayıt altına alınmamıştır.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Komitenin yetki, yeter sayı (quorum) ve karar alma kurallarının tanımlanmamış olması (Charter'da karar yetki matrisi yok).

Bulgu 5.3.2 - Bilgi Güvenliği Komitesinde Sahipsiz Aksiyonlar: Şubat 2026 toplantısında 127 kritik ve 612 yüksek zafiyet ile %64 yama uyumluluğu görüşülmüş, ancak aksiyon maddeleri dokümante edilmemiş, sorumlu ve termin atanmamıştır. Komitede görüşülen bu veriler Yönetim Kurulu Dashboard'una yansıtılmamıştır (Bkz. Bulgu 5.1.4).

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Komite kararlarını takip edecek bir aksiyon takip sürecinin olmaması ve komiteden Kurula eskalasyon yolunun tanımlanmaması.
- **Öneri:** Tüm komitelerde standart tutanak şablonu (karar, aksiyon, sorumlu, termin) kullanılmalı; CISO, Risk ve İç Denetim katılımı zorunlu tutulmalı ve aksiyonlar bir sonraki toplantıda takip edilmelidir.

Bulgu 5.3.3 - CISO'nun Bağımsızlığı: IT Organization Chart'a göre CISO, Infrastructure Manager'a raporlamaktadır. Böylece yama ve altyapı süreçlerini denetlemesi gereken CISO, bu süreçlerden sorumlu kişiye bağlıdır.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Güvenlik fonksiyonunun operasyonel bir alt birim olarak konumlandırılması; "Görevler Ayrılığı (Segregation of Duties)" ilkesinin organizasyon tasarımında dikkate alınmaması.
- **Öneri:** CISO, CEO'ya veya Yönetim Kurulu/Risk Komitesine doğrudan raporlayacak şekilde konumlandırılmalıdır.

Bulgu 5.3.4 - RACI Matrisindeki Boşluklar: Cloud Security, AI Governance, DORA Compliance ve NIS2 Compliance faaliyetleri için RACI matrisi boştur. Vendor Management faaliyetinde hiçbir role "R (Responsible)" atanmamıştır. İç Denetim tüm faaliyetlerde yalnızca "I (Informed)" konumundadır.

- **Risk Seviyesi: Medium**
- **Root Cause Analysis (RCA):** RACI'nin yeni regülasyon ve teknoloji alanlarına göre güncellenmemesi.

- **Öneri:** RACI matrisi tamamlanmalı; her faaliyet için tek bir "A" ve en az bir "R" atanmalı, DORA ve NIS2 sorumlulukları netleştirilmelidir.

5.4 BT Risk, Tedarikçi ve Politika Yönetimi (COBIT APO12 / APO10 / APO01)

Bulgu 5.4.1 - BT Risk Kütüğü: IT Risk Register en son Mayıs 2022'de güncellenmiş olup yalnızca 5 risk içermektedir. Yapay Zeka Riski, Bulut Konsantrasyon Riski, DORA, NIS2, Jeopolitik Risk ve Üçüncü Taraf Bağımlılığı değerlendirilmemiştir. KRI Dashboard 32 tedarikçi riski gösterirken kütükte yalnızca tek bir "Vendor Failure" riski bulunmaktadır.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Risk yönetiminin yaşayan bir süreç olmaktan çıkması; güncel tehdit ve regülasyon değişikliklerinin risk değerlendirmesine yansıtılmaması.
- **Öneri:** Risk kütüğü eksik riskler eklenerek yenilenmeli, en az yıllık ve önemli değişikliklerde güncellenmeli, risk iştahı eşikleriyle ilişkilendirilmelidir.

Bulgu 5.4.2 - Tedarikçi Yönetişimi: Vendor Governance Framework (Versiyon 1.0, Nisan 2021) kapsamında kritik tedarikçi tanımı, gözden geçirme sıklığı, çıkış stratejisi (Exit Strategy), alt yüklenici izleme ve performans metrikleri tanımlanmamıştır. Buna rağmen iç kontrol matrisinde Vendor Review "Pass" görünmekte, KRI Dashboard 32 tedarikçi riski (eşik <5) göstermekte ve IA-004 (Vendor Risk Reviews Missing) bulgusu Şubat 2024'ten beri açık durmaktadır.

- **Risk Seviyesi: High** (DORA üçüncü taraf gereksinimleri açısından)
- **Root Cause Analysis (RCA):** Tedarikçi yönetiminin yalnızca Satınalma süreci olarak görülmesi; risk ve güvenlik fonksiyonlarının sürece dahil edilmemesi.
- **Öneri:** Çerçeve DORA gereksinimlerine göre güncellenmeli; kritik tedarikçiler tanımlanmalı, yıllık değerlendirme ve çıkış planları zorunlu hale getirilmelidir.

Bulgu 5.4.3 - Politika Gözden Geçirmeleri: Policy Governance Standard (Ocak 2021) politikaların yıllık gözden geçirilmesini zorunlu kılmaktadır. Ancak Bilgi Güvenliği Politikası ve IAM Politikası en son 2022'de, Risk Yönetimi Politikası ve Tedarikçi Politikası en son 2021'de gözden geçirilmiştir.

- **Risk Seviyesi: Medium**
- **Root Cause Analysis (RCA):** Doküman kontrol sürecinin işletilmemesi ve politika sahiplerinin atanmaması.
- **Öneri:** Tüm politikalar güncel regülasyonlara (DORA, NIS2) göre gözden geçirilmeli ve politika takvimi takip edilmelidir.

5.5 Performans İzleme, İç Kontrol ve Güvence (COBIT MEA01 / MEA02 / MEA03)

Bulgu 5.5.1 - KPI Dashboard'da Hatalı Durum Gösterimi: Q1 2026 KPI Dashboard'daki beş göstergenin tamamı hedefin altında kalmasına rağmen "Green" olarak işaretlenmiştir: Erişilebilirlik %99,1 (hedef %99,95), Kritik Olay Çözümü %72 (hedef %95), Yama Uyumluluğu %64 (hedef

%95), Değişiklik Başarı Oranı %81 (hedef %95), Erişim Gözden Geçirme Tamamlanma %58 (hedef %100).

- **Risk Seviyesi: Critical**
- **Root Cause Analysis (RCA):** Durum renklerinin hedef/gerçekleşen değerlerden otomatik hesaplanmaması, manuel olarak belirlenmesi.

Bulgu 5.5.2 - KRI Eşiklerinin Aşılmasına Rağmen "Green" Durum: KRI Dashboard'daki tüm göstergeler eşik değerlerini aşmıştır: Kritik Zafiyet 127 (eşik <10), Yüksek Zafiyet 612 (eşik <50), Açık Denetim Bulgusu 24 (eşik <5), Başarısız Değişiklik %19 (eşik <%5), Tedarikçi Riski 32 (eşik <5). Buna rağmen genel durum "Green" olarak raporlanmıştır.

- **Risk Seviyesi: Critical**
- **Root Cause Analysis (RCA):** Eşik aşımlarında uygulanacak eskalasyon kurallarının tanımlanmamış olması (Risk Appetite ve Charter'da "Not Defined").
- **Öneri:** KPI/KRI durumları kural bazlı ve otomatik hesaplanmalı; eşik aşımları tanımlı bir eskalasyon süreciyle Risk Komitesine ve Yönetim Kuruluna iletilmelidir.

Bulgu 5.5.3 - Kanıtsız İç Kontrol Test Sonuçları: Internal Control Matrix'te Access Review, Patch Review, Vendor Review ve Incident Review kontrollerinin tamamı "Pass" olarak raporlanmış, ancak hiçbir test kanıtı eklenmemiştir (Not Attached). Diğer kanıtlar bu sonuçlarla çelişmektedir: erişim gözden geçirme tamamlanma oranı %58 ve IA-001 Ocak 2024'ten beri açık; yama uyumluluğu %64 ve IA-002 Ekim 2023'ten beri açık; tedarikçi değerlendirmesi için IA-004 açık; kritik olay çözüm oranı %72.

- **Risk Seviyesi: Critical**
- **Root Cause Analysis (RCA):** Kontrol testlerinin kontrol sahipleri tarafından kendi kendine ve kanıt standardı olmadan yapılması; ikinci savunma hattının (Risk/Uyum) test sonuçlarını doğrulamaması.
- **Öneri:** Kontrol testleri bağımsız kişilerce, örneklem ve kanıt dosyası ile yeniden yapılmalı; kanıtı olmayan kontroller "Etkin Değil" olarak sınıflandırılmalıdır.

Bulgu 5.5.4 - Kapatılmayan Denetim Bulguları: Audit Issue Tracker'daki 5 bulgunun tamamı açıktır: IA-003 DR Testing Missing (Temmuz 2023), IA-005 Logging Coverage Incomplete (Ağustos 2023), IA-002 Weak Patch Management (Ekim 2023), IA-001 Missing Access Review (Ocak 2024) ve IA-004 Vendor Risk Reviews Missing (Şubat 2024). Yönetim yanıtı yalnızca "Planned" şeklindedir; termin ve sorumlu bulunmamaktadır. Açık bulgu sayısı Tracker'da 5, KRI Dashboard'da 24, Kurul Dashboard'unda 0 olarak raporlanmaktadır.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** Bulgu takibinin yönetim seviyesinde sahiplenilmemesi ve tek bir doğru bulgu kaynağının (single source of truth) bulunmaması.
- **Öneri:** Tüm bulgular tek bir kayıtta birleştirilmeli, her birine sorumlu ve termin atanmalı ve vadesi geçen bulgular Denetim Komitesine raporlanmalıdır.

Bulgu 5.5.5 - İç Denetim Planının Risk Odaklı Olmaması: 2026 İç Denetim Planında yalnızca Payroll, Travel Expenses ve Procurement denetimleri yer almakta; IAM, Siber Güvenlik, DORA, NIS2, Bulut Güvenliği ve Zafiyet Yönetimi planlanmamıştır. Plan 2022 tarihli risk değerlendirmesine dayanmaktadır.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** İç denetim planlamasının güncel risk değerlendirmesine dayanmaması ve İç Denetimin BT yönetişiminde yalnızca "bilgilendirilen" rolde kalması.
- **Öneri:** 2026 planı güncel risk değerlendirmesiyle revize edilmeli; IAM, siber güvenlik ve DORA/NIS2 uyum denetimleri plana eklenmelidir.

Bulgu 5.5.6 - Kanıtsız COBIT Öz Değerlendirmesi: COBIT Self Assessment'ta EDM01, EDM02, EDM03, APO01, APO12, BAI01, DSS01, DSS05 ve MEA01 süreçlerinin tamamına en yüksek yetkinlik seviyesi olan 5 verilmiştir. Değerlendirme BT Yönetimi tarafından kendi kendine yapılmış, kanıt referansı bulunmamakta (N/A) ve bağımsız gözden geçirme yapılmamıştır.

- **Risk Seviyesi: High**
- **Root Cause Analysis (RCA):** COBIT'in gerçek bir yönetim aracı olarak değil, uyum görüntüsü oluşturmak amacıyla kullanılması.
- **Öneri:** COBIT değerlendirmesi kanıta dayalı olarak bağımsız bir ekip (İç Denetim veya dış danışman) tarafından yeniden yapılmalıdır.

6. COBIT Yetkinlik Değerlendirmesi

BT Yönetiminin öz değerlendirmesinde tüm süreçler 5 (Optimize) seviyesinde görünmektedir. Denetim kanıtlarına göre süreçlerin büyük bölümü **"Başlangıç (Initial)"** seviyesindedir:

Süreç	Öz Değerlendirme	Denetçi Görüşü	Gerekçe (Kanıt)
EDM01	5	**1**	Charter 2021'den beri güncellenmemiş; karar yetkisi ve eskalasyon tanımsız.
EDM02	5	**1**	Stratejik programlar gecikmeli ve bütçe aşımlı; fayda takibi yok.
EDM03	5	**1**	Risk iştahı metriksiz ve Kurul onaysız.
APO01	5	**1**	RACI boşlukları, CISO'nun Infrastructure Manager'a bağlı olması, politikaların güncel olmaması.
APO12	5	**1**	2022'den beri güncellenmeyen 5 riskli kütük.
BAI01	5	**1**	IAM ve DR "Red"; 8-11 ay gecikme, %28-34 bütçe aşımı.
DSS01	5	**2**	Operasyon metrikleri ölçülüyor ancak hedefler tutmuyor (%99,1 erişilebilirlik, %81 değişiklik başarısı).

Süreç	Öz Değerlendirme	Denetçi Görüşü	Gerekçe (Kanıt)
DSS05	5	**1**	127 kritik zafiyet, %64 yama uyumluluğu, açık loglama bulgusu (IA-005).
MEA01	5	**1**	KPI/KRI'lar hedefi tutmadığı halde "Green"; Kurul raporu gerçeği yansıtmıyor.

7. Risk Değerlendirmesi

Risk Kategorisi	Risk Seviyesi	Açıklama ve Olası Etki
Yönetim Raporlamasının Güvenilirliği	**Critical**	Kurul 127 kritik zafiyeti "0" olarak görüyor; yanlış bilgiyle karar alınması ve yönetim sorumluluğu (DORA/NIS2) ihlali.
İç Kontrol Etkinliği	**Critical**	Kanıtsız "Pass" sonuçları ve "Green" KPI/KRI'lar, kontrol zafiyetlerini gizleyerek siber olay ve regülatör yaptırımı riskini artırır.
Yönetişim ve Gözetim	**Critical**	Kurul komitesi kaydı yok; komitelerde karar ve aksiyon alınmıyor, sorunlar eskale edilmiyor.
Siber Güvenlik Duruşu	**High**	127 kritik / 612 yüksek zafiyet, %64 yama uyumluluğu, kullanılmayan €1,3M güvenlik bütçesi ve bağımsız olmayan CISO.
Strateji ve Program Teslimi	**High**	IAM ve DR programları "Red"; gecikmeler kimlik ve felaket kurtarma risklerini uzatır.
Üçüncü Taraf ve Regülasyon Uyumu	**High**	Tanımsız tedarikçi çerçevesi, 32 tedarikçi riski, RACI'de sahipsiz DORA/NIS2 sorumlulukları.

8. Yönetim Sunumu (Executive Briefing)

Sayın Vertex Capital Group Yönetim Kurulu ve Üst Yönetimi,

Bilgi Sistemleri Denetim ekibi olarak gerçekleştirdiğimiz BT yönetişimi ve iç kontrol denetimi sonucunda ulaştığımız temel bulgular aşağıda özetlenmiştir:

1. **Algı ve Gerçeklik Arasındaki Uçurum:** Kurula sunulan raporlar "GREEN" ve "0 kritik bulgu" gösterirken, şirketin kendi operasyonel kayıtlarında 127 kritik zafiyet, 24 açık denetim bulgusu ve %64 yama uyumluluğu bulunmaktadır.
2. **Göstergelerin İşlevsizliği:** KPI ve KRI'ların tamamı hedef dışında olduğu halde "Green" raporlanmakta, iç kontroller kanıtsız "Pass" almakta ve COBIT öz değerlendirmesi kanıtsız olarak tam puan göstermektedir.

3. **Karar Alamayan Yönetişim:** Komitelerde karar, aksiyon, sorumlu ve termin bulunmamakta; CISO bağımsız değildir ve güvenlik bütçesinin %62'si kullanılmamıştır.

Acil Aksiyon Planı (Öneri):

1. **Raporlama ve Gözetim (Acil - İlk 30 Gün):**
    - Kurul Siber Dashboard'unun KRI/KPI ve tarama verileriyle düzeltilerek Yönetim Kuruluna gerçek durumun sunulması.
    - KPI/KRI durumlarının kural bazlı hesaplanması ve eşik aşımları için eskalasyon kurallarının belirlenmesi.
    - Kullanılmayan €1,3M güvenlik bütçesinin kritik zafiyet giderimi ve IAM programına yönlendirilmesi.
2. **Yönetişim Yapısının Düzeltilmesi (Kısa Vade - İlk 90 Gün):**
    - IT Governance Charter, risk iştahı (metrik, eşik ve Kurul onayı) ve RACI matrisinin güncellenmesi.
    - CISO'nun bağımsız raporlama hattına alınması; komite tutanaklarında karar, aksiyon, sorumlu ve termin zorunluluğu getirilmesi.
    - Açık iç denetim bulgularına (IA-001 - IA-005) sorumlu ve termin atanması; iç kontrollerin kanıtla yeniden test edilmesi.
3. **Güvence ve Uyum (Orta Vade - İlk 180 Gün):**
    - BT Risk Kütüğünün eksik risklerle (AI, bulut konsantrasyonu, DORA, NIS2, jeopolitik, üçüncü taraf) yenilenmesi.
    - 2026 İç Denetim Planının IAM, siber güvenlik ve DORA/NIS2 denetimlerini kapsayacak şekilde revize edilmesi.
    - Tedarikçi yönetişim çerçevesinin DORA'ya göre güncellenmesi ve COBIT değerlendirmesinin bağımsız olarak yeniden yapılması.